

1. Executive Summary

The incident involves unusual activity from IP 203.0.113.45, which was previously allowed for external penetration testing. Several attacks from this IP were recorded outside the scheduled test period. The affected systems are the web and API infrastructure of Acme Financial Services.

The main finding is that the external test IP might have been used without permission or compromised.

The key recommendation is to remove this IP from the access list immediately and to apply time-limited access policies for all external test partners.

2. Scope and Method

In this analysis, **API, Web, Email, and WAF logs** were examined. Each data source was reviewed based on **time, IP address, and event type** to rebuild the full timeline of the incident.

All log timestamps were **converted to UTC** to keep consistency across sources. The analysis focused only on **actual evidence** found in the logs, without making assumptions or guesses.

3. Timeline (UTC)

- 1. According to the email logs, phishing emails were sent from IP 203.0.113.45. The logs also show that some users clicked on the links contained in these emails.

2024-10-15 09:00:23	=security@acme-finance.com	=user1@acme.com	URGENT: Verify Your Account - Action Required	yes	203.0.113.45	2024-10-15 06:00:23+00:00
2024-10-15 09:00:25	=security@acme-finance.com	=user2@acme.com	URGENT: Verify Your Account - Action Required	no		2024-10-15 06:00:25+00:00
2024-10-15 09:00:27	=security@acme-finance.com	=user3@acme.com	URGENT: Verify Your Account - Action Required	yes	203.0.113.45	2024-10-15 06:00:27+00:00
2024-10-15 09:00:29	=security@acme-finance.com	=user4@acme.com	URGENT: Verify Your Account - Action Required	no		2024-10-15 06:00:29+00:00
2024-10-15 09:00:31	=security@acme-finance.com	=user5@acme.com	URGENT: Verify Your Account - Action Required	yes	203.0.113.45	2024-10-15 06:00:31+00:00
2024-10-15 09:00:33	=security@acme-finance.com	=user6@acme.com	URGENT: Verify Your Account - Action Required	no		2024-10-15 06:00:33+00:00

- 2-) Shortly after that, the web server logs show that the attacker used the username, password, and token obtained from the phishing emails to log into the system and started making SQL injection attempts.

2024-10-15 09:18:38	1523	/login		200	8928	203.0.113.45	Mozilla/5.0 (Windows NT 10.0; Win64; x64) Chrome/118.0	2024-10-15 06:18:38+00:00
2024-10-15 09:18:15	1523	/dashboard		200	8934	203.0.113.45	Mozilla/5.0 (Windows NT 10.0; Win64; x64) Chrome/118.0	2024-10-15 06:18:15+00:00
2024-10-15 09:20:30	1523	/dashboard/search	token=AAPL:OK:1234	503	567	203.0.113.45	Mozilla/5.0 (Windows NT 10.0; Win64; x64) Chrome/118.0	2024-10-15 06:20:30+00:00
2024-10-15 09:21:15	1523	/dashboard/search	token=AAPL	503	567	203.0.113.45	Mozilla/5.0 (Windows NT 10.0; Win64; x64) Chrome/118.0	2024-10-15 06:21:15+00:00
2024-10-15 09:22:00	1523	/dashboard/search	token=AAPL:UNION SELECT * FROM users	503	567	203.0.113.45	Mozilla/5.0 (Windows NT 10.0; Win64; x64) Chrome/118.0	2024-10-15 06:22:00+00:00
2024-10-15 09:23:45	1523	/dashboard/search	token=AAPL:/5000000R/1a1c	200	136789	203.0.113.45	Mozilla/5.0 (Windows NT 10.0; Win64; x64) Chrome/118.0	2024-10-15 06:23:45+00:00
2024-10-15 09:24:10	1523	/dashboard/export	format=csv	200	892341	203.0.113.45	Mozilla/5.0 (Windows NT 10.0; Win64; x64) Chrome/118.0	2024-10-15 06:24:10+00:00
2024-10-15 09:30:00	1523	/dashboard/home		200	8934	203.0.113.45	Mozilla/5.0 (Windows NT 10.0; Win64; x64) Chrome/118.0	2024-10-15 06:30:00+00:00

- 3-) At this point, the API logs reveal a critical vulnerability. As described in *materials/api_docs.pdf*, while the system checks if the token is valid, it does not verify which objects the token owner (ID) actually has access to. In addition, due to improper rate limit enforcement across several endpoints, the attacker—using ID 1523—was able to scan and access objects belonging to user IDs 1523 through 1538.

Note: ⚠️ Authorization checks validate token but may not verify account ownership.

Note: ⚠️ Rate limiting may not be strictly enforced on all endpoints.

2024-10-15 06:45:10	1523	/api/v1/login	POST	200	267	203.0.113.45	Acme-Mobile-Android/3.2.0		2024-10-15 06:45:10+00:00	
2024-10-15 06:46:30	1523	/api/v1/portfolio/1523	GET	1523	200	156	203.0.113.45	Acme-Mobile-Android/3.2.0	jwt_token_1523_stolen	2024-10-15 06:46:30+00:00
2024-10-15 06:47:15	1523	/api/v1/portfolio/1524	GET	1524	200	143	203.0.113.45	Acme-Mobile-Android/3.2.0	jwt_token_1523_stolen	2024-10-15 06:47:15+00:00
2024-10-15 06:47:18	1523	/api/v1/portfolio/1525	GET	1525	200	138	203.0.113.45	Acme-Mobile-Android/3.2.0	jwt_token_1523_stolen	2024-10-15 06:47:18+00:00
2024-10-15 06:47:21	1523	/api/v1/portfolio/1526	GET	1526	200	147	203.0.113.45	Acme-Mobile-Android/3.2.0	jwt_token_1523_stolen	2024-10-15 06:47:21+00:00
2024-10-15 06:47:24	1523	/api/v1/portfolio/1527	GET	1527	200	141	203.0.113.45	Acme-Mobile-Android/3.2.0	jwt_token_1523_stolen	2024-10-15 06:47:24+00:00
2024-10-15 06:47:27	1523	/api/v1/portfolio/1528	GET	1528	200	139	203.0.113.45	Acme-Mobile-Android/3.2.0	jwt_token_1523_stolen	2024-10-15 06:47:27+00:00
2024-10-15 06:47:30	1523	/api/v1/portfolio/1529	GET	1529	200	144	203.0.113.45	Acme-Mobile-Android/3.2.0	jwt_token_1523_stolen	2024-10-15 06:47:30+00:00
2024-10-15 06:47:33	1523	/api/v1/portfolio/1530	GET	1530	200	142	203.0.113.45	Acme-Mobile-Android/3.2.0	jwt_token_1523_stolen	2024-10-15 06:47:33+00:00
2024-10-15 06:47:36	1523	/api/v1/portfolio/1531	GET	1531	200	148	203.0.113.45	Acme-Mobile-Android/3.2.0	jwt_token_1523_stolen	2024-10-15 06:47:36+00:00
2024-10-15 06:47:39	1523	/api/v1/portfolio/1532	GET	1532	200	145	203.0.113.45	Acme-Mobile-Android/3.2.0	jwt_token_1523_stolen	2024-10-15 06:47:39+00:00
2024-10-15 06:47:42	1523	/api/v1/portfolio/1533	GET	1533	200	140	203.0.113.45	Acme-Mobile-Android/3.2.0	jwt_token_1523_stolen	2024-10-15 06:47:42+00:00
2024-10-15 06:47:45	1523	/api/v1/portfolio/1534	GET	1534	200	146	203.0.113.45	Acme-Mobile-Android/3.2.0	jwt_token_1523_stolen	2024-10-15 06:47:45+00:00
2024-10-15 06:47:48	1523	/api/v1/portfolio/1535	GET	1535	200	143	203.0.113.45	Acme-Mobile-Android/3.2.0	jwt_token_1523_stolen	2024-10-15 06:47:48+00:00
2024-10-15 06:47:51	1523	/api/v1/portfolio/1536	GET	1536	200	149	203.0.113.45	Acme-Mobile-Android/3.2.0	jwt_token_1523_stolen	2024-10-15 06:47:51+00:00
2024-10-15 06:47:54	1523	/api/v1/portfolio/1537	GET	1537	200	141	203.0.113.45	Acme-Mobile-Android/3.2.0	jwt_token_1523_stolen	2024-10-15 06:47:54+00:00
2024-10-15 06:47:57	1523	/api/v1/portfolio/1538	GET	1538	200	147	203.0.113.45	Acme-Mobile-Android/3.2.0	jwt_token_1523_stolen	2024-10-15 06:47:57+00:00

4-) The logs below show that the WAF, positioned right behind the app and session management servers, did not block some of the attacks. This happened because the attacker's token was valid and there were existing API vulnerabilities, which allowed part of the malicious traffic to pass through the WAF's filtering logic.

2024-10-15 09:20:30	981173	HIGH	DETECT	203.0.113.45	/dashboard/search	SQL Injection Attempt - OR 1=1	yes	2024-10-15 09:20:30+00:00
2024-10-15 09:21:15	981318	CRITICAL	BLOCK	203.0.113.45	/dashboard/search	SQL Injection - DROP TABLE	yes	2024-10-15 09:21:15+00:00
2024-10-15 09:22:00	981257	HIGH	BLOCK	203.0.113.45	/dashboard/search	SQL Injection - UNION SELECT	yes	2024-10-15 09:22:00+00:00
2024-10-15 09:23:45	981001	MEDIUM	DETECT	203.0.113.45	/dashboard/search	Suspicious SQL Pattern	no	2024-10-15 09:23:45+00:00
2024-10-15 09:00:23	950107	HIGH	DETECT	203.0.113.45	/verify-account.php	Suspicious Link Pattern	no	2024-10-15 09:00:23+00:00

3.2 Attack Vectors

- Vector 1 – Phishing: Malicious emails were sent from the attacker IP and some users clicked the links, exposing credentials or tokens.
- Vector 2 – Unauthorized scanning (Reconnaissance): The attacker ran port scans and probed endpoints outside the planned test window.
- Vector 3 – Abuse of authentication tests: The attacker tried many logins with invalid or stolen credentials.
- Vector 4 – API parameter manipulation: The attacker changed API parameters to request data and accessed records outside the normal test period.

3.3 Classification

- MITRE ATT&CK: The incident includes *phishing activity* (T1566), *active scanning* (T1595), and the *use of valid or stolen accounts* (T1078). These actions show that the attacker first collected information, then gained access using stolen credentials, and finally exploited weaknesses in the API.
- OWASP: The case relates to A05 – Security Misconfiguration, A07 – Identification and Authentication Failures, and A01 – Broken Access Control, since the API did not properly check user ownership or enforce rate limits.

Reconnaissance 11 techniques	Resource Development 8 techniques	Initial Access 11 techniques	Execution 17 techniques	Persistence 23 techniques	Privilege Escalation 14 techniques	Defense Evasion 47 techniques	Credential Access 17 techniques	Discovery 34 techniques	Lateral Movement 9 techniques	Collection 17 techniques	Command and Control 18 techniques	Exfiltration 5 techniques	Impact 15 techniques
Active Scanning (10)	Acquire Access (10)	Content Injection (10)	Cloud Administration Command (10)	Account Manipulation (10)	Abuse Elevation Control Mechanism (10)	Abuse Elevation Control Mechanism (10)	Adversary-in-the-Middle (10)	Account Discovery (10)	Exploitation of Remote Services (10)	Adversary-in-the-Middle (10)	Application Layer Protocol (10)	Automated Exfiltration (10)	Account Access Removal (10)
Gather Victim Host Information (10)	Acquire Infrastructure (10)	Drive-by Compromise (10)	Command and Scripting Interpreter (10)	BITS Jobs (10)	Access Token Manipulation (10)	Access Token Manipulation (10)	Brute Force (10)	Application Window Discovery (10)	Internal Spearfishing (10)	Archive Collected Data (10)	Communication Through Removable Media (10)	Data Transfer State Limits (10)	Data Destruction (10)
Gather Victim Identity Information (10)	Compromise Accounts (10)	Exploit Public-Facing Application (10)	Container Administration Command (10)	Boot or Logon Autostart Execution (10)	Account Manipulation (10)	Account Manipulation (10)	Credentials from Password Stores (10)	Browser Information Discovery (10)	Lateral Tool Transfer (10)	Audio Capture (10)	Content Injection (10)	Exfiltration Over Alternative Protocol (10)	Data Encrypted for Impact (10)
Gather Victim Network Information (10)	Compromise Infrastructure (10)	External Remote Services (10)	Container Administration Command (10)	Boot or Logon Autostart Execution (10)	Account Manipulation (10)	Account Manipulation (10)	Exploitation for Credential Access (10)	Cloud Infrastructure Discovery (10)	Remote Service Session Hijacking (10)	Automated Collection (10)	Data Obfuscation (10)	Exfiltration Over C2 Channel (10)	Data Manipulation (10)
Gather Victim Org Information (10)	Develop Capabilities (10)	Hardware Additions (10)	Deploy Container (10)	Cloud Application Integration (10)	Boot or Logon Initialization Scripts (10)	Boot or Logon Initialization Scripts (10)	Debugger Evasion (10)	Cloud Service Dashboard (10)	Remote Services (10)	Clipboard Data (10)	Data Encoding (10)	Exfiltration Over Other Network Medium (10)	Data Defacement (10)
Phishing for Information (10)	Establish Accounts (10)	Phishing (10)	ESXi Administration Command (10)	Cloud Application Integration (10)	Boot or Logon Initialization Scripts (10)	Boot or Logon Initialization Scripts (10)	Delay Execution (10)	Cloud Service Dashboard (10)	Remote Services (10)	Clipboard Data (10)	Dynamic Resolution (10)	Exfiltration Over Other Network Medium (10)	Disk Wipe (10)
Search Closed Sources (10)	Obtain Capabilities (10)	Replication Through Removable Media (10)	Exploration for Client Execution (10)	Compromise Host Software Binary (10)	Create or Modify System Process (10)	Create or Modify System Process (10)	Deobfuscate/Decode Files or Information (10)	Cloud Service Dashboard (10)	Replication Through Removable Media (10)	Data from Cloud Storage (10)	Encrypted Channel (10)	Exfiltration Over Physical Medium (10)	Email Bombing (10)
Search Open Technical Databases (10)	Stage Capabilities (10)	Supply Chain Compromise (10)	Input Injection (10)	Create Account (10)	Create or Modify System Process (10)	Create or Modify System Process (10)	Input Capture (10)	Cloud Service Dashboard (10)	Software Deployment Tools (10)	Data from Configuration Repository (10)	Fallback Channels (10)	Exfiltration Over Physical Medium (10)	Endpoint Denial of Service (10)
Search Open Websites/Domains (10)	Search Threat Vendor Data (10)	Trusted Relationship (10)	Inter-Process Communication (10)	Event Triggered Execution (10)	Domain or Tenant Policy Modification (10)	Domain or Tenant Policy Modification (10)	Modify Authentication Process (10)	Container and Resource Discovery (10)	Taint Shared Content (10)	Data from Local System (10)	Ingress Tool Transfer (10)	Scheduled Transfer (10)	Network Denial of Service (10)
Search Victim-Owned Websites (10)		Valid Accounts (10)	Native API (10)	Exclusive Control (10)	Event Triggered Execution (10)	Event Triggered Execution (10)	Multi-Factor Authentication Interception (10)	Debugger Evasion (10)	Use Alternate Authentication Material (10)	Data from Network Shared Drive (10)	Non-Application Layer Protocol (10)	Transfer Data to Cloud Account (10)	Resource Hijacking (10)
		Wi-Fi Networks (10)	Scheduled Task/Job (10)	External Remote Services (10)	Execution Guardrails (10)	Execution Guardrails (10)	Network Sniffing (10)	Device Driver Discovery (10)		Data from Removable Media (10)	Non-Standard Port (10)	Service Stop (10)	System Shutdown/Reboot (10)
			Serverless Execution (10)	Hijack Execution Flow (10)	Hijack Execution Flow (10)	Hijack Execution Flow (10)	OS Credential Dumping (10)	File and Directory Discovery (10)		Data Staged (10)	Proxy (10)	System Shutdown/Reboot (10)	
			Shared Modules (10)	Implant Internal Image (10)	Process Injection (10)	Process Injection (10)	Steal Application Access Token (10)	Group Policy Discovery (10)		Email Collection (10)	Remote Access Tools (10)		
			Software Deployment Tools (10)	Modify Authentication Process (10)	Scheduled Task/Job (10)	Scheduled Task/Job (10)	Steal or Forge Authentication Certificates (10)	Local Storage Discovery (10)		Input Capture (10)	Traffic Signaling (10)		
			System Services (10)	Modify Registry (10)	Valid Accounts (10)	Valid Accounts (10)	Steal or Forge Authentication Certificates (10)	Log Enumeration (10)		Screen Capture (10)	Web Service (10)		
			User Execution (10)										

3.4 Root Cause

Because the authorized test IP was leaked or misused, phishing emails from this address were not blocked. Some users clicked the links and gave the attacker valid credentials. Later, weak API controls and missing rate limits allowed the attacker to move deeper into the system.

3.5 Impact Analysis

The overall impact was limited; the attack attempts did not fully succeed. However, the unauthorized use of a trusted pentest IP damaged the integrity of the testing process and weakened the organization's external access and SecOps security model.

4. Architecture Review

4.1 Observed Weaknesses

- No time or source limits: External test IPs were allowed all the time, so attacks could happen outside the planned test window.
- Weak access control: There was no central system to approve or remove external IP permissions.
- Low visibility and weak SIEM alerts: Logs from API, web, and WAF were not correlated in real time, and no alerts were triggered for the off-schedule scans.
- Mail security gap: Phishing emails from trusted IPs were not filtered because the IP was whitelisted.
- API misconfiguration: Rate limiting was not working correctly, and ownership checks were missing for user tokens.
- Unclear responsibilities with 3rd parties: If the pentest team was compromised, poor coordination and control with external partners exposed the company's SecOps process.

4.2 Target Architecture (Short Summary)

- Perimeter: Internet → WAF (reverse proxy, rate limit, bot protection) → Load Balancer → Web/API zone.
- Monitoring & Detection: WAF, Web, API, and Email logs sent to a central SIEM, using UTC time for clear correlation.

- Mail Security Layer: Use stronger filtering, SPF/DKIM/DMARC validation, and real-time sandboxing for test and external sources.
- Access & Test Control: External partners connect only through a time-limited VPN or jump host with token-based approval.
- Internal Segmentation: Separate VLANs for management, data, and services; only trusted IPs can reach sensitive systems.
- Response Loop: SIEM detects anomaly → automatic quarantine/block → SOC team validation → long-term fix.

Key Principles

1. Time-limited and least-privilege external access.
2. Defense-in-depth: WAF + rate limit + segmentation + endpoint hardening.
3. Central SIEM monitoring and quick log correlation.
4. Improved mail filtering and phishing detection.
5. Clear rules and audit trail for 3rd-party testing and cooperation.

4.3 Recommended Controls and Reasoning

Immediate (P0):

Remove IP 203.0.113.45 from all allowlists and block access at the firewall.

Reason: Stops any ongoing unauthorized activity.

Short Term (1–7 days):

- Apply time-based VPN or jump-host for external tests; replace static IP allowlists with token/time access.
- Update WAF rules for rate limiting and anomaly detection.
- Strengthen API authentication with better token validation and failed login logout.
- Add email filtering rules to detect phishing from trusted but misused IPs.
Reason: Quick reduction of exposure and better detection of similar attacks.

Mid Term (1–4 weeks):

- Enable real-time log flow into SIEM for correlation of WAF, API, and Email events.
- Review network segmentation and move key services into isolated VLANs.
- Formalize pentest management: approval process, IP list, time window, and responsible contacts.
Reason: Increases detection and control over third-party actions.

Long Term (1–3 months):

- Test new controls with red-team simulations.
- Deploy PAM or centralized allowlist management for partner access.

- Create SOAR playbooks for automatic blocking and alerting when off-schedule activity is detected.
- Update company procedures for 3rd-party security participation, ensuring accountability.
Reason: Builds long-term resilience and improves SecOps maturity.

5.Response and Remediation

0–24 Hours (Immediate Actions)

- IP 203.0.113.45 removed from allowlists and blocked in all firewalls.
- Similar traffic patterns automatically quarantined by WAF.
- SOC notified and SIEM monitoring priority increased.
- All related logs and emails preserved as evidence with hash validation.

1–2 Weeks (Short-Term Fixes)

- Time-restricted access policies activated for all test partners.
- WAF and API configurations updated to enforce rate limits.
- Mail gateway tuned for stronger phishing detection.
- Centralized logging integrated in SIEM for correlation and alerting.

1–3 Months (Mid- to Long-Term Improvements)

- Official process for 3rd-party access and pentest management established.
- Automated SIEM/SOAR responses created for off-schedule or abnormal activities.
- Plan and deploy PAM or bastion host for external users.
- Review all SecOps workflows with internal audit and update documentation.
- Conduct awareness sessions on secure testing and external access.

Compliance Notes

- Actions align with ISO/IEC 27001 A.9 (Access Control) and A.13 (Communications Security).
- The incident handling process follows SOC 2 Type II – Security & Availability standards.